Detecting an SSH Brute Force Attack and Post-Compromise Malware Upload Using Wazuh SIEM with VirusTotal Integration

Security Operations Center (SOC) Detection Engineering Lab

Prepared by Nikhil Gowda

1. Executive Summary

This project simulates a realistic, two-stage attack against a Linux host and demonstrates end-to-end detection using Wazuh SIEM. An attacker performs an SSH brute-force attack against a victim server, successfully authenticates, escalates privileges, and uploads a malicious file. Wazuh detects each stage of the attack chain in real time: the brute-force attempts, the successful authentication following repeated failures, the newly created file via File Integrity Monitoring (FIM), and the malicious verdict via an automated VirusTotal lookup.

Every screenshot below has the key finding boxed in red so the relevant line is easy to spot at a glance.

2. Objectives

- Detect SSH brute-force attacks in real time using Wazuh's built-in SSH/syslog rules.
- Detect a successful login following multiple failed attempts (a strong compromise indicator).
- Monitor a target directory with File Integrity Monitoring (FIM) and detect file uploads in real time.
- Integrate VirusTotal with Wazuh to automatically check uploaded files against 60+ AV engines.
- Map all detections to the MITRE ATT&CK framework.
- Troubleshoot a real detection gap and document the fix.

3. Lab Architecture

Role	Machine	Hypervisor	IP Address
Wazuh Manager / SIEM	Wazuh OVA (Linux)	VirtualBox	192.168.31.110
Victim / Wazuh Agent	Kali Linux	VMware	192.168.31.172
Attacker	Windows host (WSL terminal)	Host OS	192.168.31.147

Attack flow: Attacker (Windows/WSL, .147) brute-forces SSH on Victim (Kali, .172, Wazuh agent); telemetry is forwarded to the Wazuh Manager (.110), which queries VirusTotal for any new file detected on the victim.

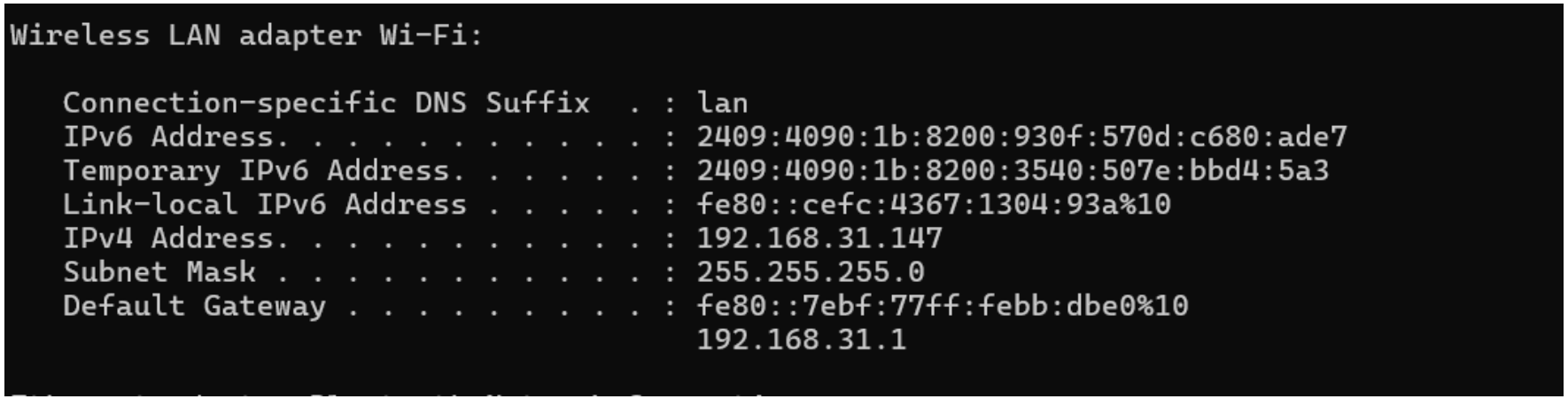


Figure 1a – Attacker-side network interface (192.168.31.147)

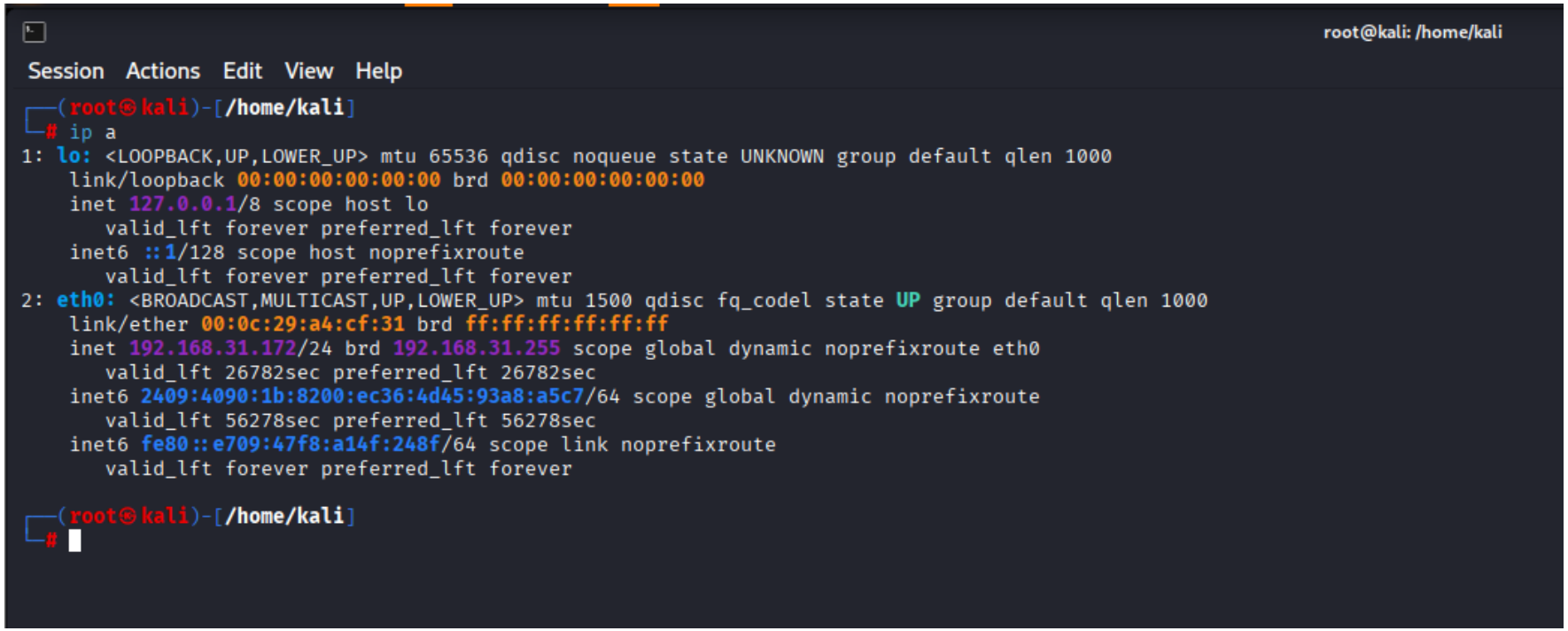


Figure 1b – Victim-side network interface, Kali agent (192.168.31.172)

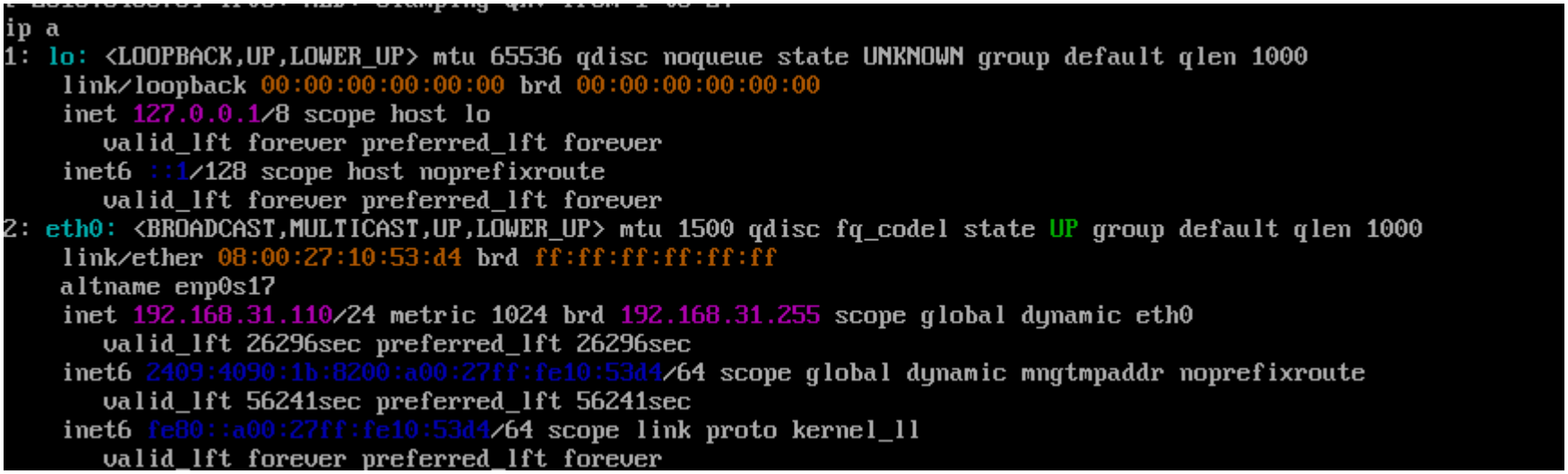


Figure 1c – Wazuh manager network interface (192.168.31.110)

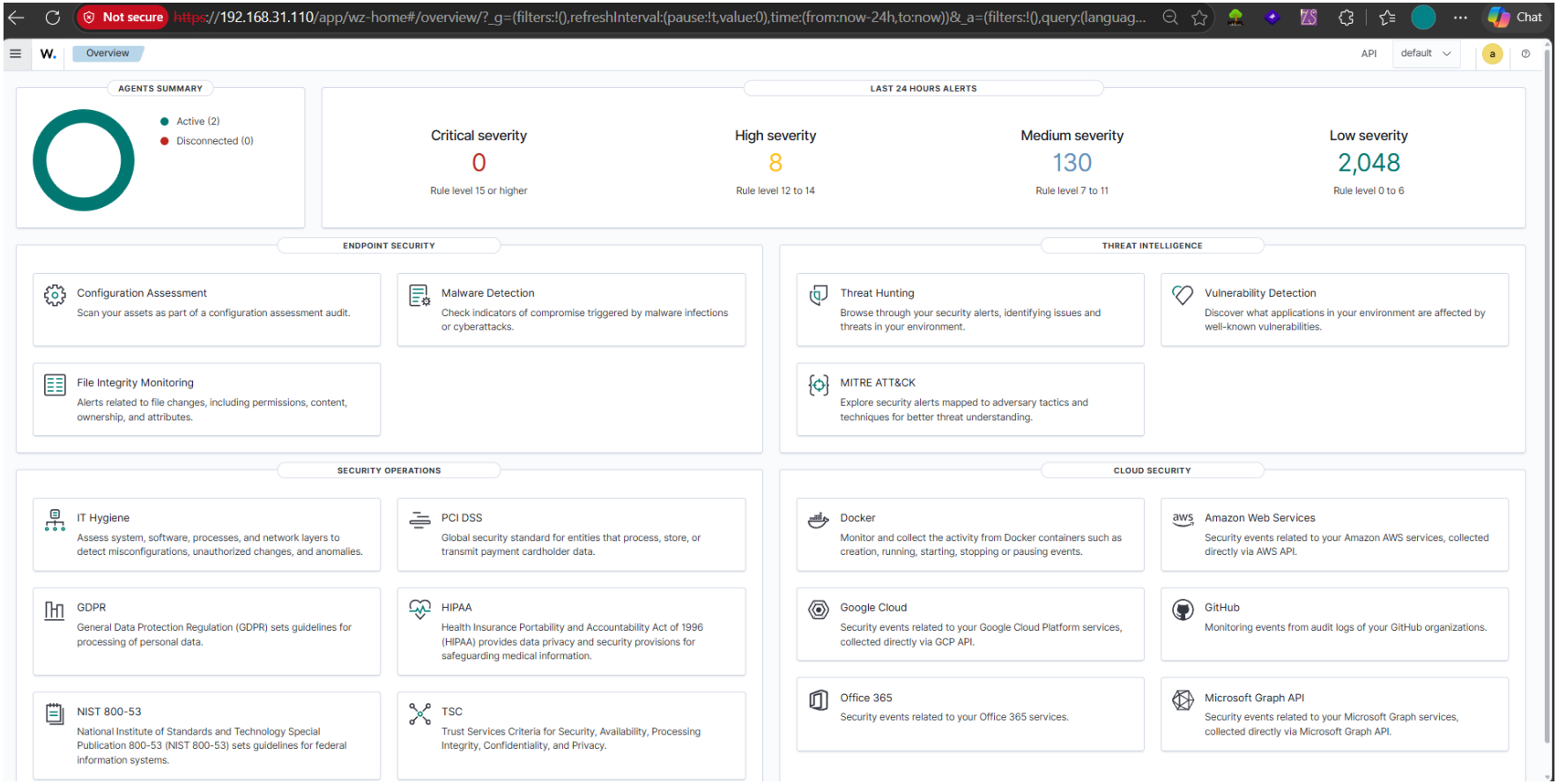


Figure 2 – Wazuh overview: 2 active agents, alert severity breakdown for the last 24 hours

4. Tools Used

Tool	Purpose
Wazuh 4.x (Manager + Agent)	SIEM: log collection, correlation, FIM, active response
Hydra v9.5	SSH brute-force attack simulation
VirusTotal API	Automated malware reputation lookup for new files
EICAR test file	Industry-standard harmless file for safely testing AV/malware detection
Kali Linux	Victim host

Tool	Purpose
WSL (Windows Subsystem for Linux)	Attacker terminal, run from the Windows host

5. Stage 1 — SSH Brute Force Attack

5.1 Attack Execution

SSH connectivity to the victim was confirmed, then Hydra was used to brute-force the SSH login with a small password wordlist. The red box below marks the exact line where Hydra reports the cracked credentials.

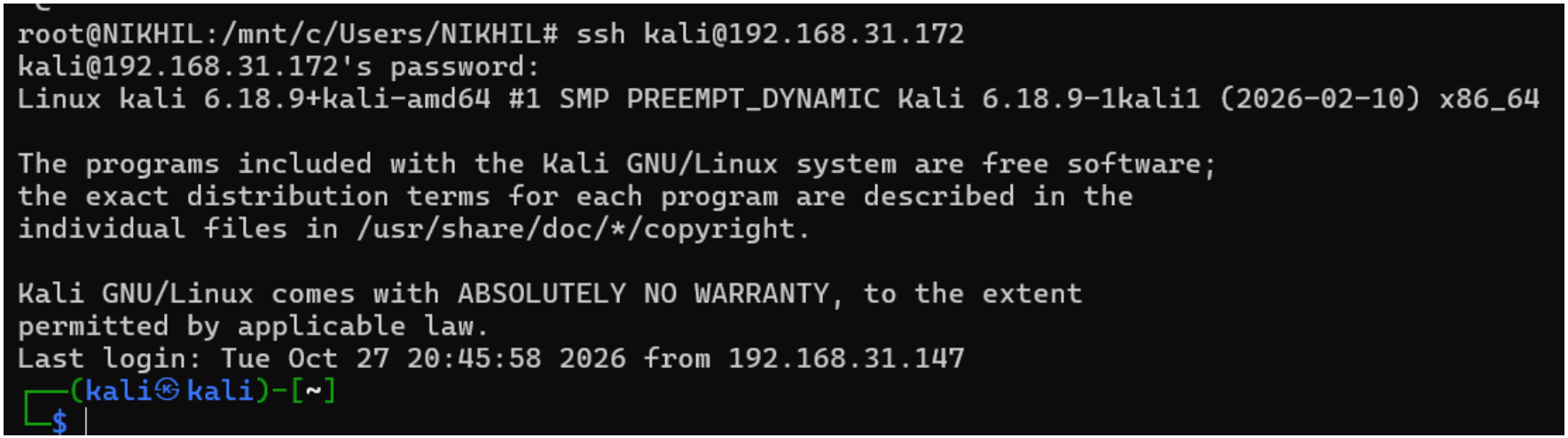


Figure 3 – Confirming SSH reachability to the victim from the attacker machine

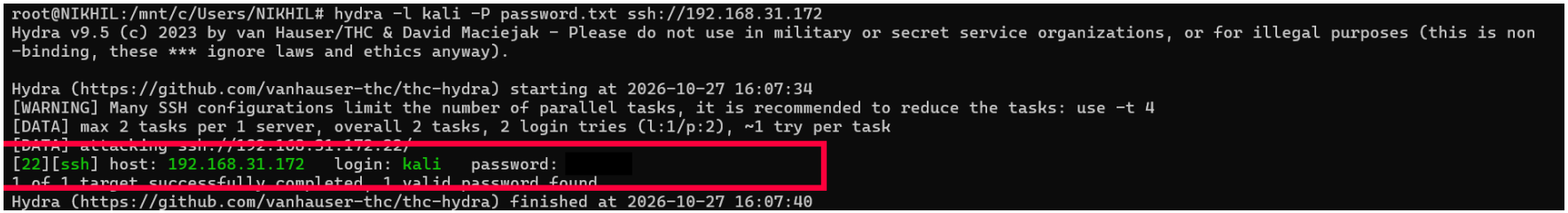


Figure 4 – Hydra cracks the SSH password for user 'kali' (password redacted) ***[Highlighted in red: key finding]***

5.2 Detection in Wazuh

Each failed login attempt generated an sshd authentication-failed alert (rule 5760, level 5). Once Hydra found the correct password, Wazuh's correlation rule fired a higher-severity alert for a successful login following multiple failures — boxed in red below, standing out from the repeated failure rows beneath it.



Oct 27, 2026 @ 21:42:19.9...	Linux	Multiple authentication failures followed by a success.	12	40112
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:12.0...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:11.9...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:11.9...	Linux	sshd: authentication failed.	5	5760
Oct 27, 2026 @ 21:41:11.9...	Linux	sshd: authentication failed.	5	5760

Figure 5 – The correlated brute-force alert (top row) vs. the repeated raw failure events below it ***[Highlighted in red: key finding]***

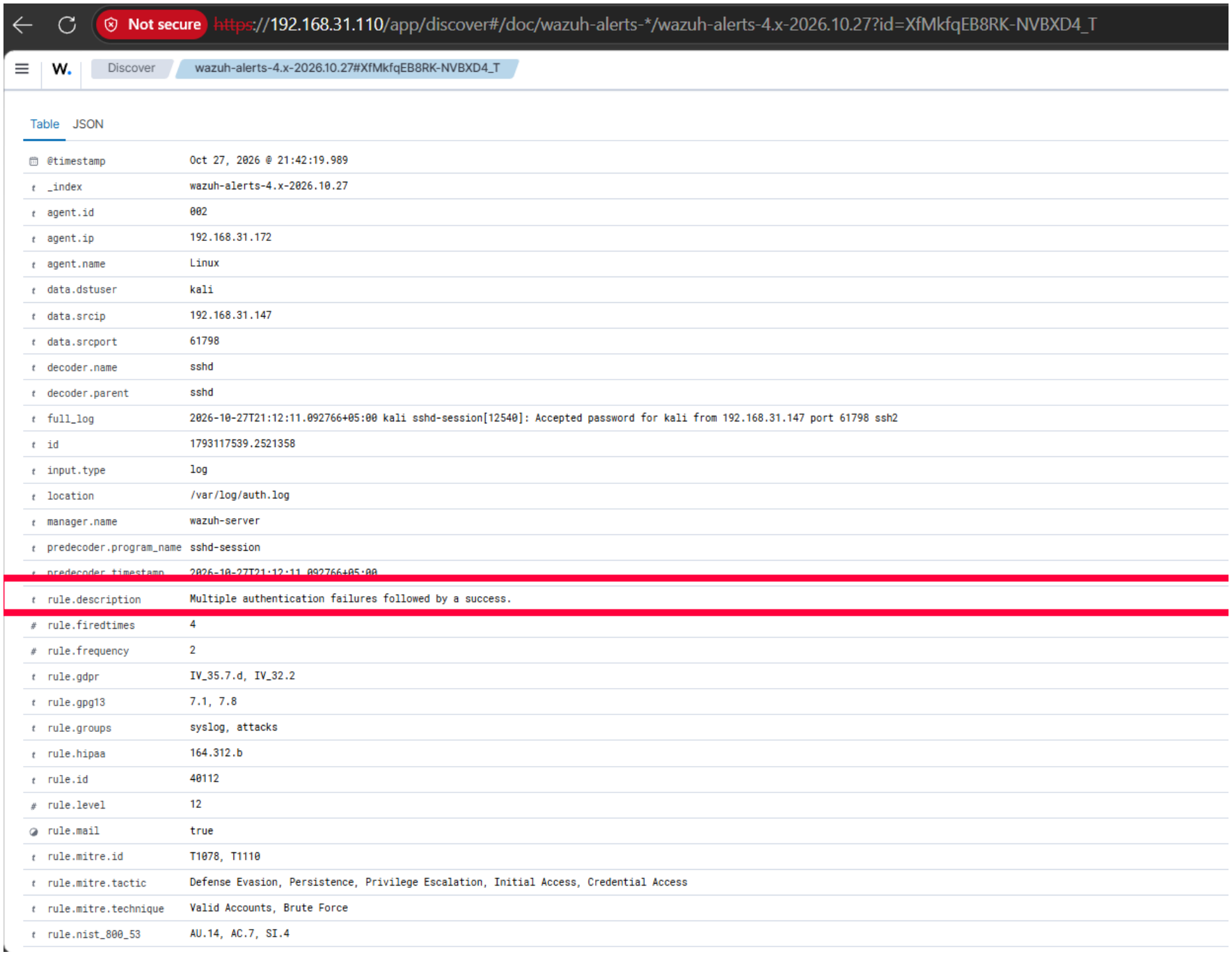

Not secure
https://192.168.31.110/app/discover#/doc/wazuh-alerts-*/wazuh-alerts-4.x-2026.10.27?id=XfMkfqEB8RK-NVBXD4_T
Discover
wazuh-alerts-4.x-2026.10.27#XfMkfqEB8RK-NVBXD4_T
Table
JSON
@timestamp Oct 27, 2026 @ 21:42:19.989
_index wazuh-alerts-4.x-2026.10.27
agent.id 002
agent.ip 192.168.31.172
agent.name Linux
data.dstuser kali
data.srcip 192.168.31.147
data.srcport 61798
decoder.name sshd
decoder.parent sshd
full_log 2026-10-27T21:12:11.092766+05:00 kali sshd-session[12540]: Accepted password for kali from 192.168.31.147 port 61798 ssh2
id 1793117539.2521358
input.type log
location /var/log/auth.log
manager.name wazuh-server
predecoder.program_name sshd-session
predecoder.timestamp 2026-10-27T21:12:11.092766+05:00
rule.description Multiple authentication failures followed by a success.
rule.firedtimes 4
rule.frequency 2
rule.gdpr IV_35.7.d, IV_32.2
rule.gpg13 7.1, 7.8
rule.groups syslog, attacks
rule.hipaa 164.312.b
rule.id 40112
rule.level 12
rule.mail true
rule.mitre.id T1078, T1110
rule.mitre.tactic Defense Evasion, Persistence, Privilege Escalation, Initial Access, Credential Access
rule.mitre.technique Valid Accounts, Brute Force
rule.nist_800_53 AU.14, AC.7, SI.4

Figure 6 – Full alert record: rule.description confirms 'Multiple authentication failures followed by a success' (rule 40112, level 12) ***[Highlighted in red: key finding]***

Key fields from the correlated alert:

Field	Value
rule.id	40112
rule.level	12 (High severity)
rule.description	Multiple authentication failures followed by a success
rule.mitre.id	T1078, T1110
rule.mitre.technique	Valid Accounts, Brute Force
data.srcip	192.168.31.147 (attacker)
data.dstuser	kali

6. Stage 2 — Post-Compromise Malware Upload

6.1 Simulated Attacker Actions

Using the cracked credentials, the attacker escalated to root on the victim and placed the EICAR test file (a standardized, harmless string recognized by all AV engines as a test signature) into the monitored directory to simulate a malicious payload drop.



Figure 7 – Attacker escalates to root on the compromised victim

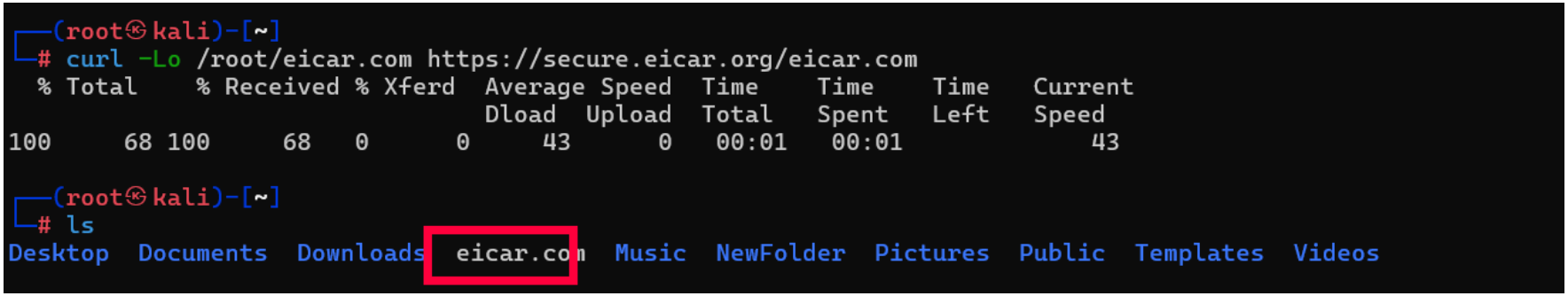


Figure 8 – EICAR test file downloaded to /root/eicar.com and confirmed on disk ***[Highlighted in red: key finding]***

6.2 File Integrity Monitoring (FIM) Detection

Wazuh's syscheck module, configured with real-time monitoring on the target directory, detected the new file within seconds of creation — the boxed row below is the exact 'File added to the system' event for eicar.com.

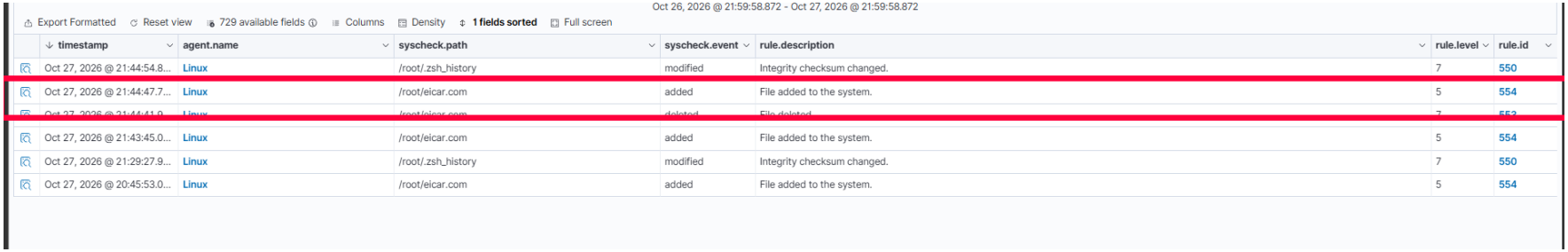


Figure 9 – Syscheck (FIM) events: eicar.com added to the monitored directory (rule 554, level 5) ***[Highlighted in red: key finding]***

6.3 VirusTotal Verdict

The Wazuh manager's VirusTotal integration automatically submitted the file hash to VirusTotal. The file was flagged as malicious by 66 of 68 AV engines, and Wazuh generated a high-severity alert correlating the FIM event with the VirusTotal verdict.

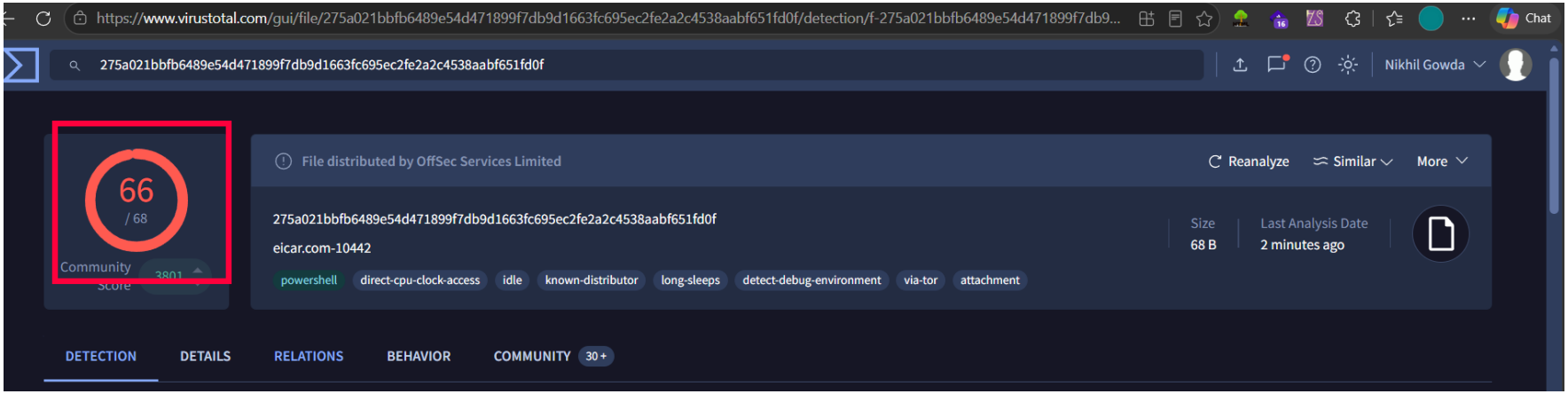


Figure 10 – VirusTotal detection result: 66/68 engines flag the file (eicar.com) ***[Highlighted in red: key finding]***

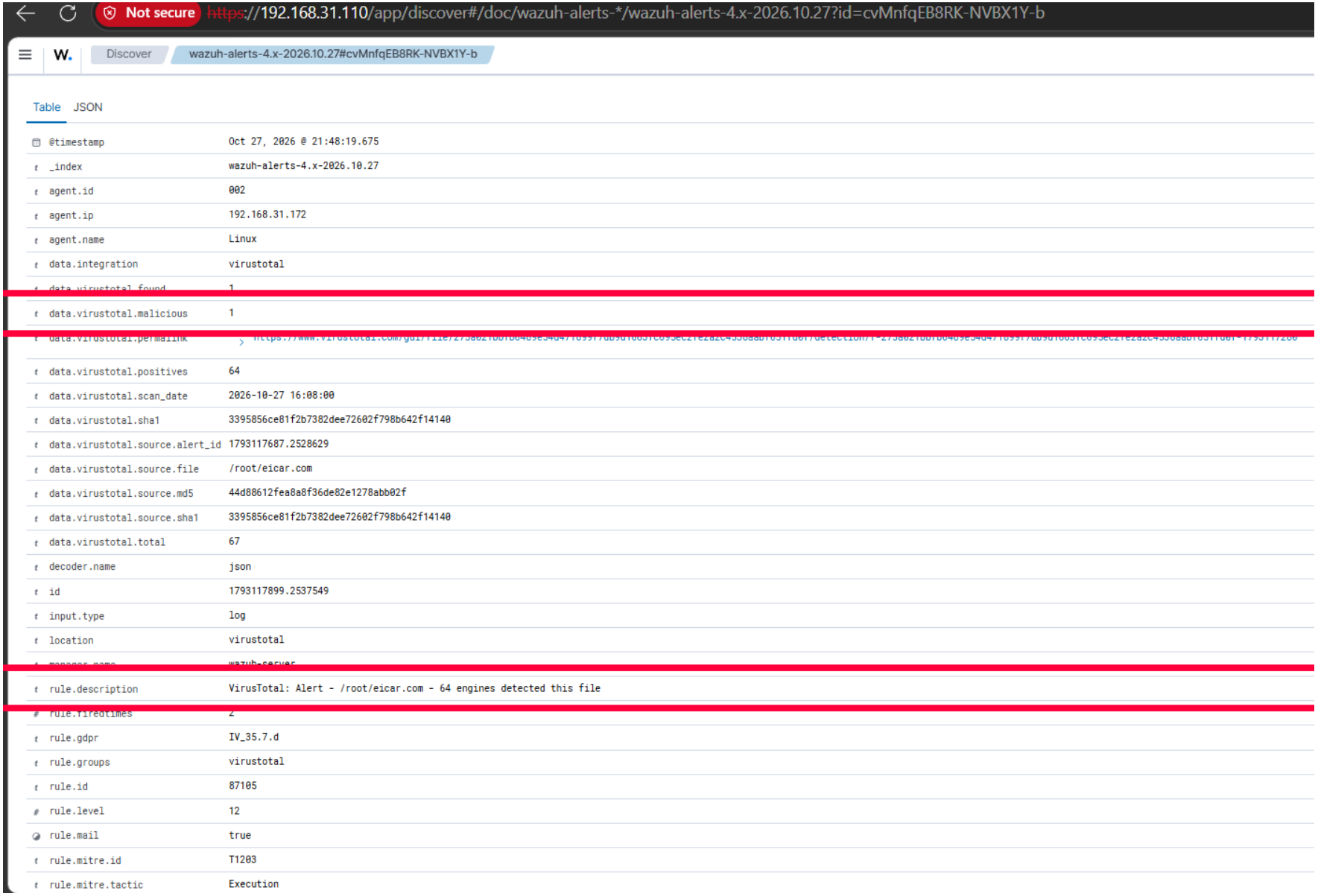


Figure 11 – Wazuh's VirusTotal alert — malicious flag and the plain-English verdict in rule.description ***[Highlighted in red: key finding]***

Key fields from the VirusTotal alert:

Field	Value
rule.id	87105
rule.level	12 (High severity)
rule.mitre.id	T1203
rule.mitre.tactic	Execution
data.virustotal.malicious	1
data.virustotal.positives	64–66 (varies slightly per scan)
data.virustotal.source.file	/root/eicar.com

7. Troubleshooting: A Real Detection Gap

During initial testing, the FIM and VirusTotal alerts did not appear even though the file was present on the victim. Root cause: the syscheck <directories> entry had been added to the Wazuh manager's own ossec.conf (watching /root on the manager itself) instead of the Kali agent's ossec.conf. Since the manager and agent are separate machines with separate filesystems, monitoring /root on the manager had no visibility into files created on the Kali victim.

- Fix: edited /var/ossec/etc/ossec.conf on the Kali agent (not the manager).
- Added <directories realtime="yes" report_changes="yes">/root</directories> inside the agent's <syscheck> block.
- Restarted the Wazuh agent on Kali (systemctl restart wazuh-agent).
- Re-triggered the file drop; FIM and VirusTotal alerts (Figures 9–11) then appeared correctly within seconds.

This reinforced an important architectural point: the manager's ossec.conf controls manager-side settings (integrations like VirusTotal), while each agent's own ossec.conf controls what is monitored on that specific endpoint. Diagnosing and fixing this kind of detection gap is a core SOC analyst skill, not just getting alerts to fire on the first try.

8. Supporting Evidence: Configuration Assessment

A CIS Benchmark scan was also run against the victim, highlighting broader hardening gaps beyond the two detections above.

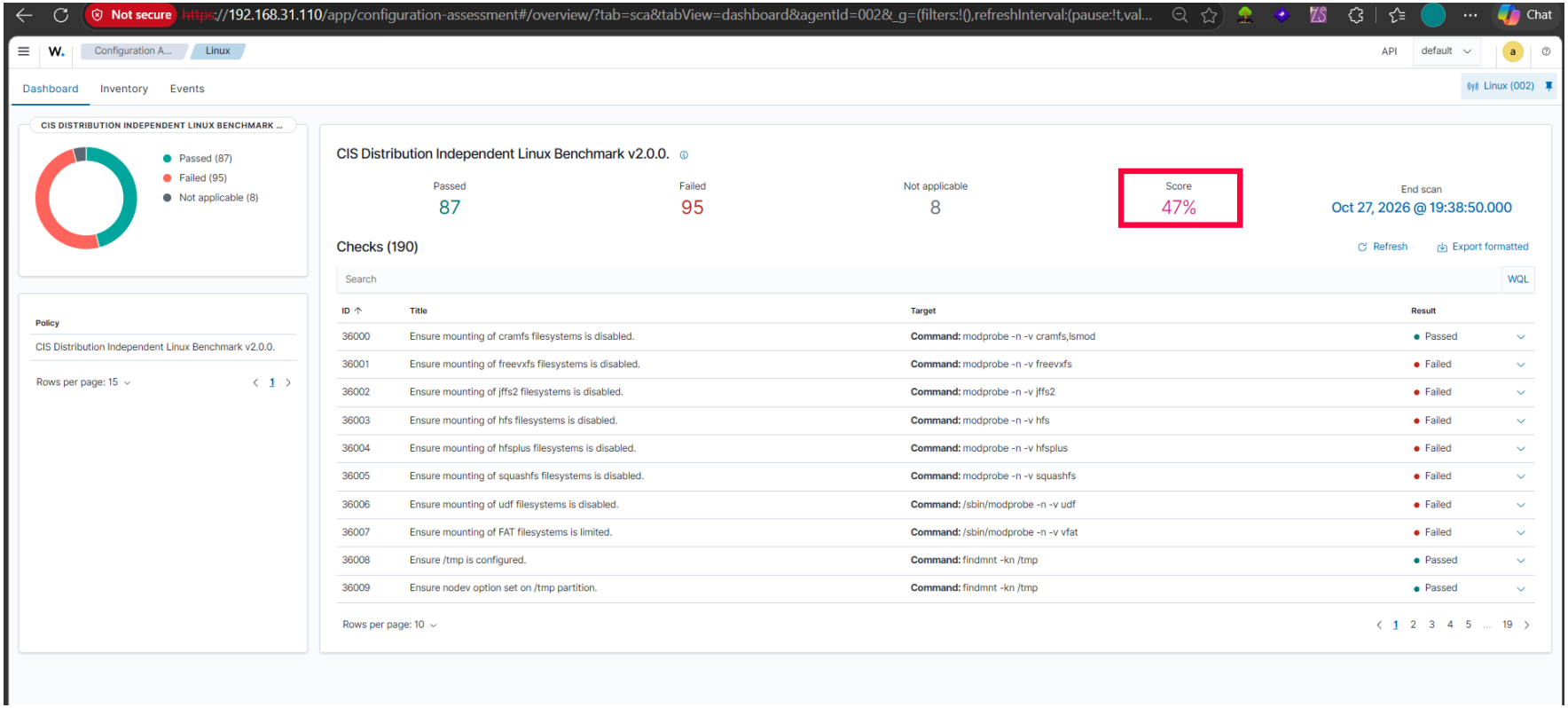


Figure 12 – CIS Benchmark score for the victim host: 47% (87 passed, 95 failed, 8 not applicable) ***[Highlighted in red: key finding]***

9. MITRE ATT&CK Mapping

Stage	Technique ID	Technique Name	Tactic
SSH brute force	T1110.001	Brute Force: Password Guessing	Credential Access
Successful login after failures	T1078	Valid Accounts	Initial Access / Persistence
File upload / drop	T1105	Ingress Tool Transfer	Command and Control
File execution risk	T1203	Exploitation for Client Execution	Execution

10. Findings & Recommendations

- The victim allowed password-based SSH authentication with a weak password, which made brute-forcing trivial — switch to key-based authentication and disable password login.
- No rate-limiting or account lockout was in place — deploy fail2ban or Wazuh Active Response (firewall-drop) to automatically block brute-force source IPs.
- The CIS benchmark scored only 47%, with 95 failed checks — prioritize remediating high-impact filesystem and SSH hardening checks.
- FIM + VirusTotal integration successfully detected a malicious file within seconds of upload, validating the detection pipeline for future, real malware.
- Configuration changes must be applied on the correct host (manager vs. agent) — verify agent.id and manager.name on every alert before troubleshooting further.

11. Conclusion

This lab demonstrated a complete, realistic attack chain — SSH brute force, successful compromise, and malicious file upload — detected end-to-end by Wazuh SIEM with VirusTotal integration. All alerts were correlated with MITRE ATT&CK techniques, and a genuine misconfiguration was identified and resolved during testing, mirroring the troubleshooting SOC analysts perform daily.